7. Politique de sécurité des systèmes d'information (version courte)

Organisme	Télémédix SAS (cas fictif)
Version	1.0, projet soumis à l'approbation de la direction générale
Diffusion	Tous les salariés ; extrait communicable aux clients
Révision	Annuelle, et après tout incident majeur ou changement de périmètre

1. Objet et engagement de la direction

Télémédix traite, pour le compte de professionnels de santé, les données de santé de leurs patients. Leur confiance et le secret médical sont la condition d'existence de l'entreprise. La direction générale s'engage à protéger ces données, à attribuer les moyens nécessaires, à respecter les obligations légales (RGPD, code de la santé publique, référentiels de l'ANS) et à améliorer la sécurité de façon continue. Elle approuve cette politique, les risques résiduels et le plan d'actions.

2. Périmètre

La politique s'applique à la plateforme Télémédix, aux activités de développement, d'exploitation et de support, à tous les salariés, stagiaires et prestataires, ainsi qu'aux fournisseurs qui interviennent sur ces activités.

3. Objectifs de sécurité

Objectif	Cible mesurable
Confidentialité des données de santé	Aucun accès non autorisé ; tout accès du personnel à un dossier est justifié et tracé
Intégrité des dossiers et des ordonnances	Toute modification est imputable à un utilisateur authentifié à deux facteurs
Disponibilité du service	Disponibilité mensuelle de 99,9 % aux heures ouvrées ; reprise en 4 heures ; perte de données maximale d'une heure
Traçabilité	Traces d'accès conservées 12 mois et protégées contre la modification
Conformité	Certifications ISO 27001 et HDS (activité 5) obtenues sous 18 mois

4. Organisation

Rôle	Responsabilités
Direction générale	Approuve la politique, arbitre les moyens, accepte les risques résiduels, préside la cellule de crise
RSSI	Pilote le système de management de la sécurité, l'analyse de risques et le plan d'actions ; rend compte directement au directeur général
DPO	Conseille et contrôle la conformité au RGPD ; est associé à tout projet traitant des données personnelles
Responsables d'équipe	Appliquent la politique dans leur périmètre ; valident les habilitations de leurs collaborateurs
Chaque collaborateur	Respecte les règles, protège ses moyens d'authentification, signale tout événement suspect
Comité sécurité (trimestriel)	Suit les risques, les incidents, les indicateurs et l'avancement du plan

5. Règles de sécurité

1. **Analyse de risques.** Une analyse EBIOS RM est tenue à jour ; tout projet ou changement majeur fait l'objet d'une analyse de risques et, si nécessaire, d'une AIPD avant sa mise en production.
2. **Accès.** Les droits sont accordés selon le besoin d'en connaître et le moindre privilège, sur comptes nominatifs, et revus chaque trimestre. Ils sont retirés le jour du départ.
3. **Authentification.** L'authentification à plusieurs facteurs est obligatoire pour tout accès d'administration et pour tout accès à des données de santé. Les secrets ne sont jamais partagés ni stockés en clair.
4. **Accès aux données de santé par le personnel.** Il est interdit par défaut. Il n'est possible que pour résoudre un incident, avec justification, durée limitée, trace et revue.
5. **Chiffrement.** Les données de santé sont chiffrées en transit et au repos ; les clés sont gérées séparément des données.
6. **Minimisation.** Aucune donnée de santé ne figure dans les notifications, les tickets, les journaux ou les environnements de test. Les consultations ne sont pas enregistrées.
7. **Développement.** Chaque modification est revue par un pair et passe les contrôles automatiques de sécurité ; les environnements sont séparés ; un test d'intrusion est réalisé chaque année.
8. **Exploitation.** Les systèmes sont inventoriés, durcis, cloisonnés et corrigés dans des délais définis ; l'administration passe par un bastion et des postes dédiés.
9. **Sauvegarde et continuité.** Les sauvegardes sont isolées de la production, immuables et testées chaque trimestre ; le plan de reprise est testé chaque année.
10. **Journalisation et détection.** Les accès et les actions d'administration sont journalisés, centralisés et surveillés.
11. **Fournisseurs.** Les données de santé ne sont confiées qu'à des hébergeurs certifiés HDS, dans l'Espace économique européen ; chaque fournisseur critique est évalué chaque année et lié par des clauses de sécurité.
12. **Postes et mobilité.** Les postes sont chiffrés, protégés et gérés par l'entreprise ; l'usage de matériels personnels pour accéder à la production est interdit.

6. Gestion des incidents

Tout événement suspect est signalé sans délai au RSSI (adresse et numéro d'astreinte dédiés). Le RSSI qualifie l'incident, déclenche si besoin la cellule de crise et tient un journal. En cas de violation de données, les clients responsables de traitement sont informés sans délai ; les notifications réglementaires (CNIL sous 72 heures, autres autorités selon les textes applicables) sont préparées avec le DPO. Chaque incident fait l'objet d'un retour d'expérience.

7. Sensibilisation

Chaque collaborateur est formé à son arrivée puis chaque année. Les administrateurs, les développeurs et le support suivent une formation adaptée à leur métier. Les dirigeants sont formés à la gestion du risque cyber.

8. Contrôle et conformité

L'application de la politique est vérifiée par des indicateurs trimestriels, un audit interne annuel et une revue de direction annuelle. Les dérogations sont écrites, limitées dans le temps et validées par le RSSI ; celles qui touchent les données de santé le sont par la direction générale.

9. Manquements

Le non-respect de cette politique peut entraîner des mesures disciplinaires prévues par le règlement intérieur, sans préjudice des poursuites pour violation du secret professionnel.

Approbation : direction générale, date et signature.